Донецький національний технічний університет



Тема 1. Мета, задачі, зміст курсу. Основні визначення. Лекція 1. Вступ до дисципліни

Предмет: Безпека та захист ОС
Розділ: Кібербезпека
Галузь: Інформаційні технології

Укладач: проф. Дорогий Я.Ю.



Лекційні питання

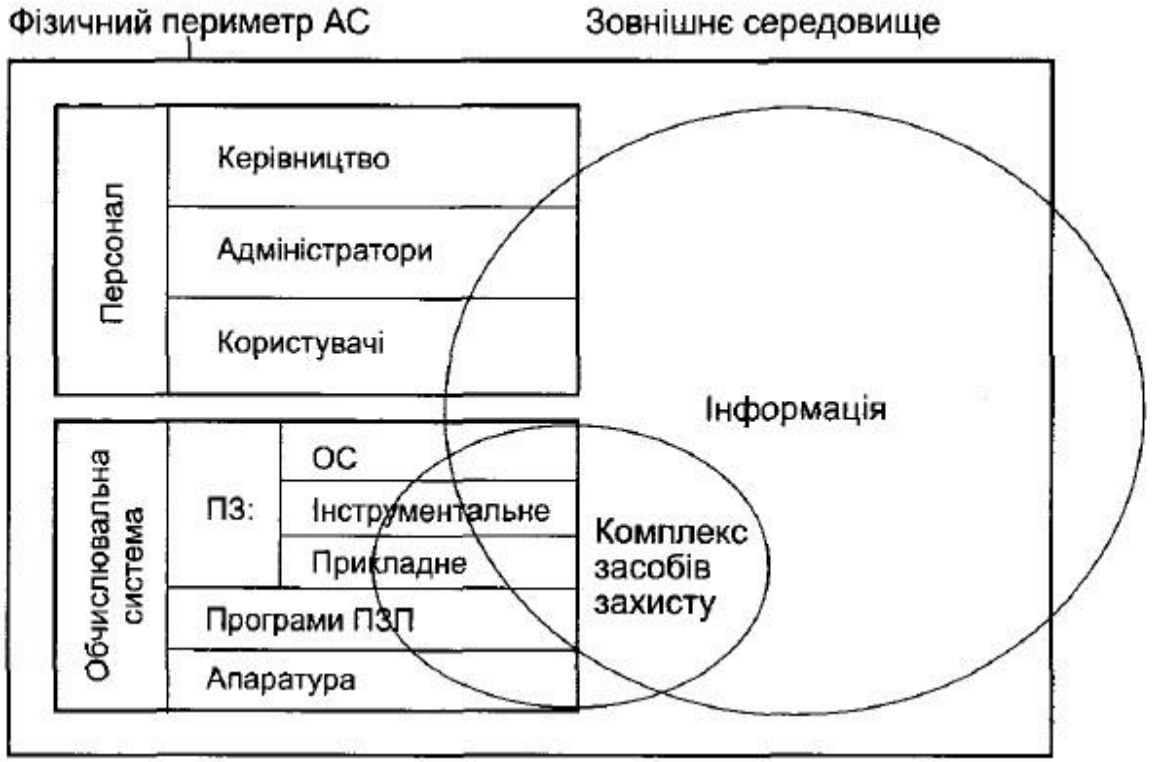
- Мета курсу
- Основна термінологія
- Структура курсу

Мета курсу

- формування у студентів навичок аналізування проблем і загроз безпеці програмного забезпечення, які виникають під час обробки інформації в інформаційно-комунікаційних системах
- надання студентам здатностей до обґрунтованого вибору засобів захисту для операційних систем відповідно до вимог національних та міжнародних стандартів
- розвиток умінь налаштування засобів захисту в операційних системах та оцінювання рівня захищеності інформації відповідно до встановлених критеріїв

Автоматизована система (АС)

- це організаційно-технічна система, що реалізує інформаційну технологію і поєднує в собі:
  - ✓ Обчислювальну систему
  - ✓ Фізичне середовище
  - ✓ Персонал
  - ✓ Інформацію



Інформаційно-комунікаційна система (ІКС)

До ІКС відносяться:

- Інформаційна система (ІС) - організаційно-технічна система, в якій реалізується технологія обробки інформації з використанням технічних і програмних засобів
- інформаційно-комунікаційна система (ІКС) - сукупність інформаційних та електронних комунікаційних систем, які у процесі обробки інформації діють як єдине ціле

Визначення наведено відповідно до ЗУ «Про захист інформації в інформаційно-комунікаційних системах»

Інформація

Відповідно до ЗУ "Про інформацію" термін інформація має наступне визначення:

- це **будь-які відомості та/або дані, які можуть бути збережені на матеріальних носіях або відображені в електронному вигляді**.

Властивості Інформації

- **Конфіденційність**
  - лише уповноважені користувачі можуть ознайомитись з інформацією
- **Цілісність**
  - лише уповноважені користувачі можуть модифікувати інформацію
- **Доступність**
  - уповноважені користувачі можуть отримати доступ до інформації, не очікуючи довше за заданий (малий) час

Безпека інформації

- стан інформації, в якому забезпечується збереження властивостей інформації, визначених політикою безпеки

Відповідно до ЗУ «Про засади інформаційної безпеки України» термін «інформаційна безпека» наступний:

- стан захищеності життєво важливих інтересів людини і громадянина, суспільства і держави, при якому запобігається завдання шкоди через неповноту, несвоєчасність та недостовірність поширюваної інформації, порушення цілісності та доступності інформації, несанкціонований обіг інформації з обмеженим доступом, а також через негативний інформаційно-психологічний вплив та умисне спричинення негативних наслідків застосування інформаційних технологій

Загроза, атака, вразливість, порушник

❑***Загроза***

- *будь-які обставини або події, що можуть бути причиною порушення політики безпеки інформації та (або) нанесення збитків ІКС*

❑ ***Атака***

- *спроба реалізації загрози*

❑ ***Вразливість системи***

- *нездатність системи протистояти реалізації певної загрози або сукупності загроз*

❑ ***Порушник, зловмисник***

- *фізична особа, яка порушує політику безпеки (навмисно або ні)*

Моделі

- ***Модель [політики] безпеки***
  - Абстрактний формалізований або неформалізований опис політики безпеки

- ***Модель загроз***
  - Абстрактний формалізований або неформалізований опис методів і засобів здійснення загроз

- ***Модель порушника***
  - Абстрактний формалізований або неформалізований опис порушника

Захищена комп’ютерна система

Захищена комп’ютерна система (англ. — trusted computer system) — комп’ютерна система, що здатна забезпечувати захист оброблюваної інформації від визначених загроз.

Спостережність

Спостережність (англ. — accountability) — властивість ІКС, що дає змогу фіксувати діяльність користувачів і процесів, використання пасивних об’єктів, а також однозначно встановлювати ідентифікатори причетних до певних подій користувачів і процесів із метою запобігання порушенню політики безпеки і (або) забезпеченню відповідальності за певні дії.

Захист інформації в ІКС

Під захистом інформації в ІКС розуміють діяльність, спрямовану на забезпечення безпеки оброблюваної в ІКС інформації та ІКС в цілому, що дає змогу запобігти реалізації загроз або унеможливити її, та зменшити ймовірність завдання збитків від реалізації загроз.

Захист інформації в ІКС полягає у створенні системи технічних (інженерних, програмно-апаратних) та нетехнічних (правових, організаційних) заходів та в підтримці її працездатності.

Система таких заходів – комплексна система захисту інформації (КСЗІ)!

Комплекс засобів захисту (КЗЗ)

Під КЗЗ розуміють сукупність програмно-апаратних засобів, що забезпечують реалізацію політики безпеки інформації. КЗЗ є складовою обчислювальної системи (див. рис. на сл. 3).

Об'єкти системи (ОС)

ОС – це елемент ресурсів обчислювальної системи, який знаходиться під керуванням КЗЗ і характеризується визначеними атрибутами й поводженням.

Розрізняють наступні види об'єктів:

- ✓Пасивні
- ✓Об'єкти-користувачі
- ✓Об'єкти-процеси

Доступ

Доступ – взаємодія двох об'єктів обчислювальної системи, коли один із них (той, що здійснює доступ) виконує дії над іншим (тим, до якого здійснюється доступ). Результатом доступу є змінення стану системи або утворення інформаційного потоку.

Правила розмежування доступу – складова політики безпеки, що регламентує правила доступу користувачів і процесів до пасивних об'єктів.

Розпізнавання об'єктів

Ідентифікація – процес розпізнавання об'єктів за їх мітками або ідентифікаторами.

Ідентифікатор – унікальний атрибут об'єкта, який дозволяє вирізнити його з поміж інших об'єктів.

Ідентифікація – процес присвоєння ідентифікаторів об'єктам.

Автентифікація, авторизація

Автентифікація – перевірка запропонованого ідентифікатора на відповідність об'єкту, пересвідчення в його справжності.

Авторизація – процедура надання користувачу визначених повноважень у системі.

Відмови

Відмова від авторства – заперечення причетності до створення або передавання якого-небудь документа чи повідомлення.

Відмова від одержання – заперечення причетності до отримання якого-небудь документа чи повідомлення.

Адекватність

Адекватність – показник реального гарантованого рівня безпеки, що відображає ступінь ефективності та надійності реалізованих засобів захисту та їхніх відповідностей поставленим задачам.

Структура курсу

1) Модель загроз для ОС
2) Концепція розробки захищених ОС
3) Комплекс засобів захисту ОС
4) Стандарти оцінювання безпеки ОС
5) Нормативно-правове регулювання в галузі
6) Засоби захисту ОС Windows
7) Засоби захисту UNIX-подібних систем
8) Архітектура безпеки і механізми захисту Android
9) Архітектура безпеки і механізми захисту iOS

Цикл лабораторних робіт

Курсом дисципліни передбачено 13 лабораторних робіт:

- 9 – на базі операційної системи Linux
- 2 – на базі операційної системи Windows
- 1 – на базі операційної системи Android
- 1 – на базі операційної системи iOS